

Web Application Penetration Test Report

Mediroza General Hospital
Security Assessment of the Public-Facing Web Application

Author: Like
Muyambango
(NetworkSaint)

Mentor: Waqas Karim,

CCIE Organisation:

Networkwalks

Programme: Batch B082 — Week 4 Capstone

Project Target: <https://medirozahospital.com>

Classification: Confidential

1. Executive Summary

As part of this engagement I carried out a black-box security review of Mediroza General Hospital's web platform at <https://medirozahospital.com>. Written permission for the test was provided by the client beforehand. The objective was to uncover weaknesses, show what an attacker could actually do with them, and recommend fixes to strengthen the organisation's overall security.

The engagement surfaced seven issues, with severities ranging from Medium to Critical. The most serious of these was a SQL injection flaw in the patient portal's login form, which let me get past authentication completely without ever having a valid password. That access exposed three private patient lab report files. Once I broke the encryption on those PDFs, one of them contained hidden metadata that led me to an old database backup left in a publicly reachable directory on the server. That backup exposed the monthly pay of all 30 hospital staff members along with the ownership stakes of the company's 10 shareholders.

Overall, the application's security posture is weak. Several critical issues would let an attacker with no credentials and no special equipment reach confidential patient records, staff pay data, and information about who owns the hospital.

Overall Risk Rating: CRITICAL — remediation should not be delayed.

2. Scope and Methodology

2.1 Scope

The engagement covered only the target agreed with the client.

Target domain: <https://medirozahospital.com>

The following activities were explicitly out of scope: social engineering, denial-of-service testing, and any assessment of systems outside the agreed domain.

2.2 Methodology

The test followed a standard four-phase black-box approach:

- **Reconnaissance** — gathering publicly available information using open-source and web-based tools.
- **Vulnerability Identification** — examining the application's behaviour for weaknesses in how it handles authentication and user input.
- **Exploitation** — proving the real-world impact of each issue through controlled testing.
- **Documentation** — recording every finding, the evidence behind it, and how to fix it, in this report.

2.3 Tools Used

- **curl** — sending HTTP requests and reviewing server responses from the command line
- **Browser developer tools** — inspecting page source and how the login form behaves
- **Networkwalks Hash Calculator** — pulling password hashes out of PDF files

- **Networkwalks Password Cracker** — cracking those PDF hashes against wordlists
- **qpdf** — decrypting PDFs once their passwords were known
- **exiftool** — reading hidden metadata embedded in PDF files
- **wget** — retrieving files from the web server
- **Claude** — reformatting raw SQL rows into readable tables

3. Findings and Proof of Exploitation

3.1 Summary Table

#	Vulnerability	Location	Risk
1	Username enumeration on the login page	patient/login.php	Medium
2	SQL injection allowing login bypass	patient/login.php	Critical
3	Encrypted PDFs reachable after the login bypass	patient/reports/	High
4	Weak PDF passwords crackable with a wordlist	patient_report_*.pdf	High
5	Sensitive metadata left inside a patient PDF	patient_report_3.pdf	Medium
6	Forgotten backup folder with directory listing on	old/	Critical
7	Confidential staff pay and shareholder data in plain	toelxdt/mediroza_db_backup_2019.sql	Critical

3.2 Finding 1 — Username Enumeration

Risk Rating: Medium **Location: patient/login.php**

Description

Username enumeration happens when a login page gives away whether a username is valid by returning a different message depending on whether the username or the password was wrong. A properly secured login form should always return the same generic message either way, so an attacker can't use it to confirm which accounts exist.

Steps Taken

I opened the patient portal's login page and compared the error messages returned for different inputs.

First, I tried a username I expected not to exist.

```
username: bob
password: test123

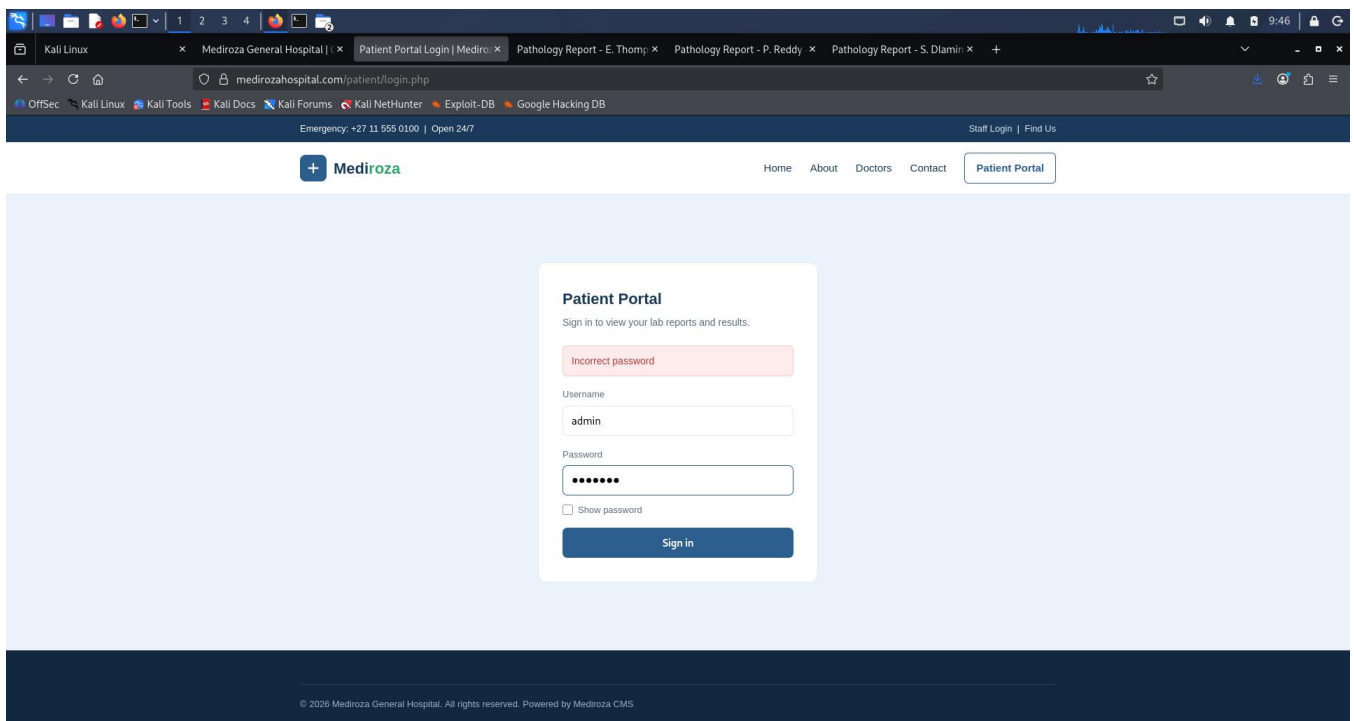
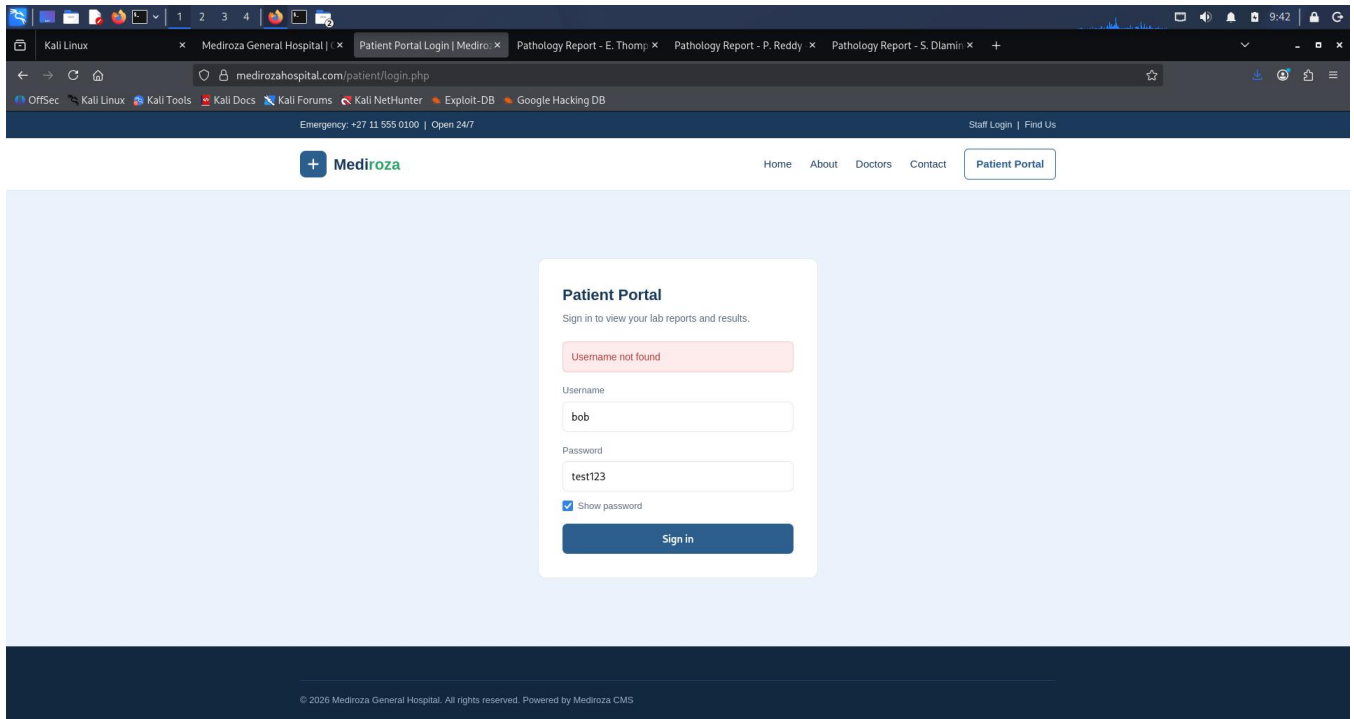
RESPONSE
Username not found
```

Then I tried a common default username.

```
username: admin
password: test123
```

```
RESPONSE
Incorrect password
```

The differing responses confirmed that **admin** is a real account on the system, leaving only the password to find.



Finding 2 — SQL Injection Login Bypass Risk Rating:

Critical **Location:** patient/login.php **Description**

SQL injection occurs when user-supplied input is inserted straight into a database query without being sanitised. This lets an attacker inject their own SQL logic to alter how the query behaves. Here, it let me strip out the password check entirely and sign in as admin with no password at all.

Steps Taken

I first tested the username field with a single quote to see how the application reacted.

```
username: admin'  
password: test123
```

RESPONSE

```
Warning: mysqli_query(): You have an error in your SQL syntax; check the manual that  
corresponds to your MySQL server version for the right syntax to use near ''' at line  
1
```

The database error confirmed that the field was vulnerable, and that the underlying query was likely built along these lines:

```
SELECT * FROM users WHERE username='admin'' AND password='test123'
```

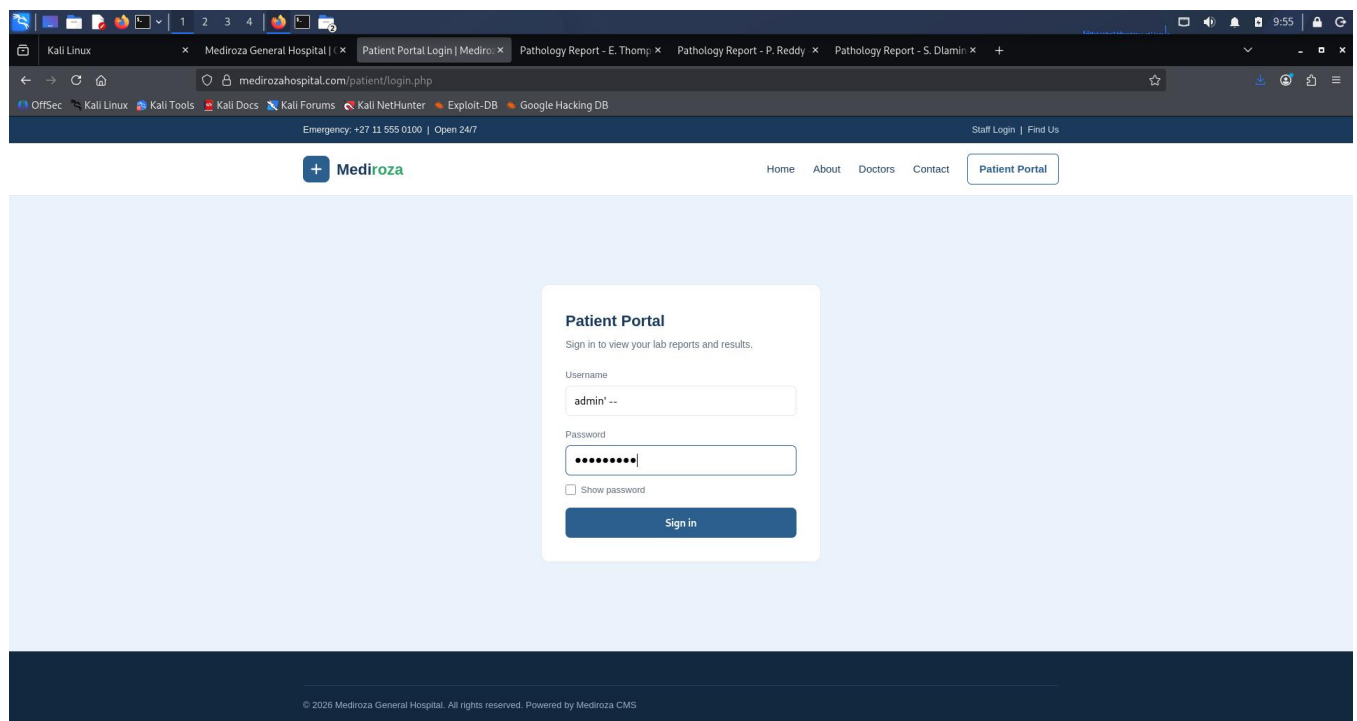
The stray quote broke the query and triggered the error. From there I built the well-known SQL injection bypass payload:

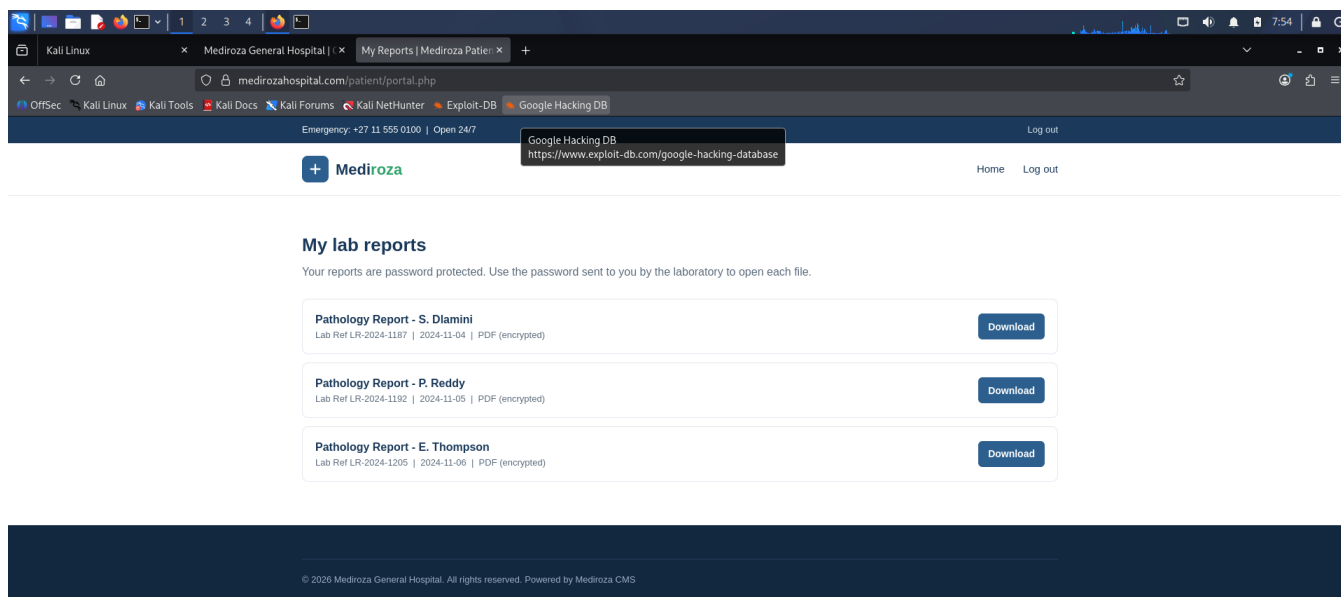
```
username: admin' --  
password: anything
```

The double dash comments out everything that follows it in SQL, turning the query into:

```
SELECT * FROM users WHERE username='admin'
```

With the password check removed entirely, the query simply returns the admin record and logs me in.





www.exploit-db.com/google-hacking-database

Finding 3 — Confidential PDFs Reachable After the Login

Bypass

Risk Rating: High **Location: patient/reports/**

Description

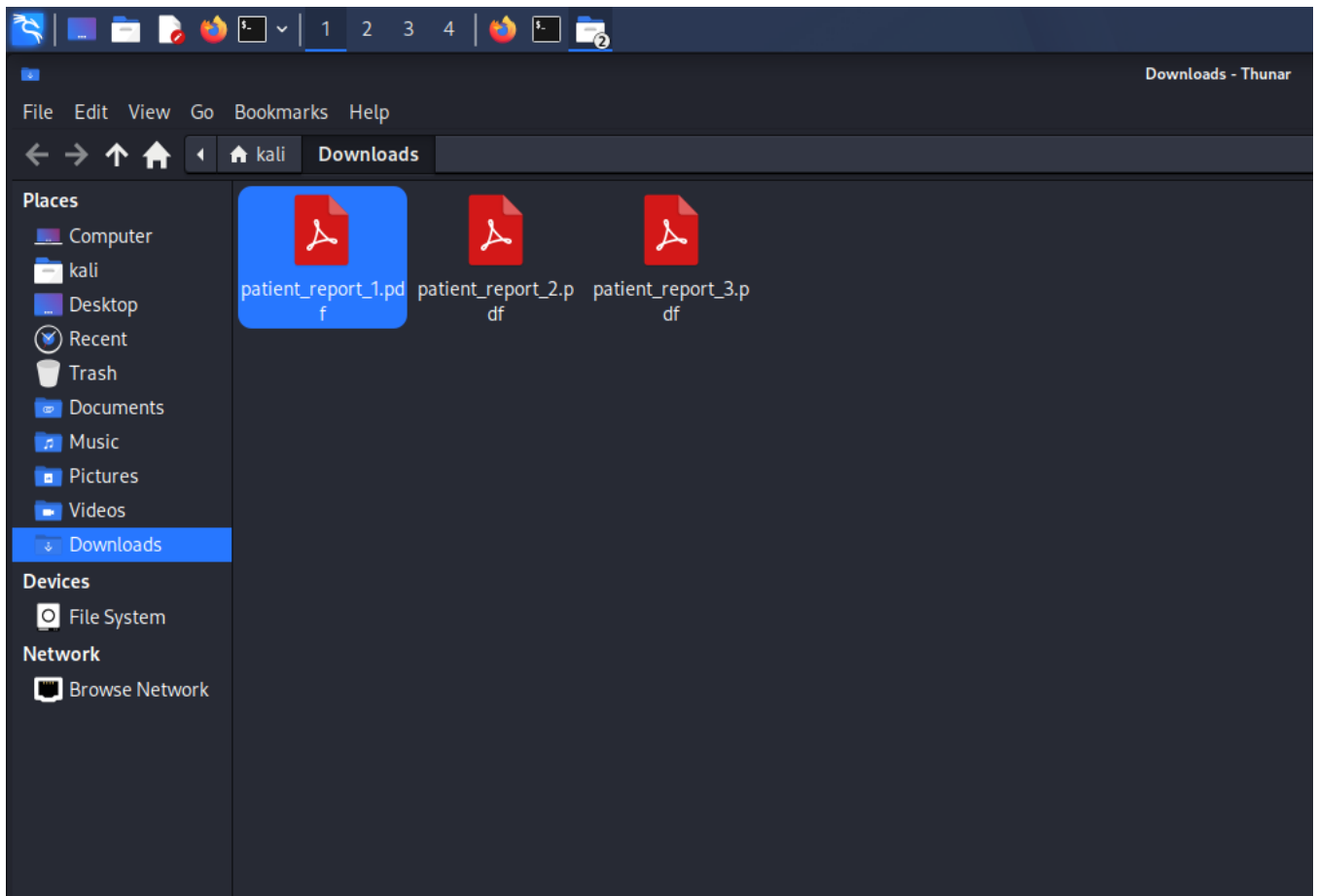
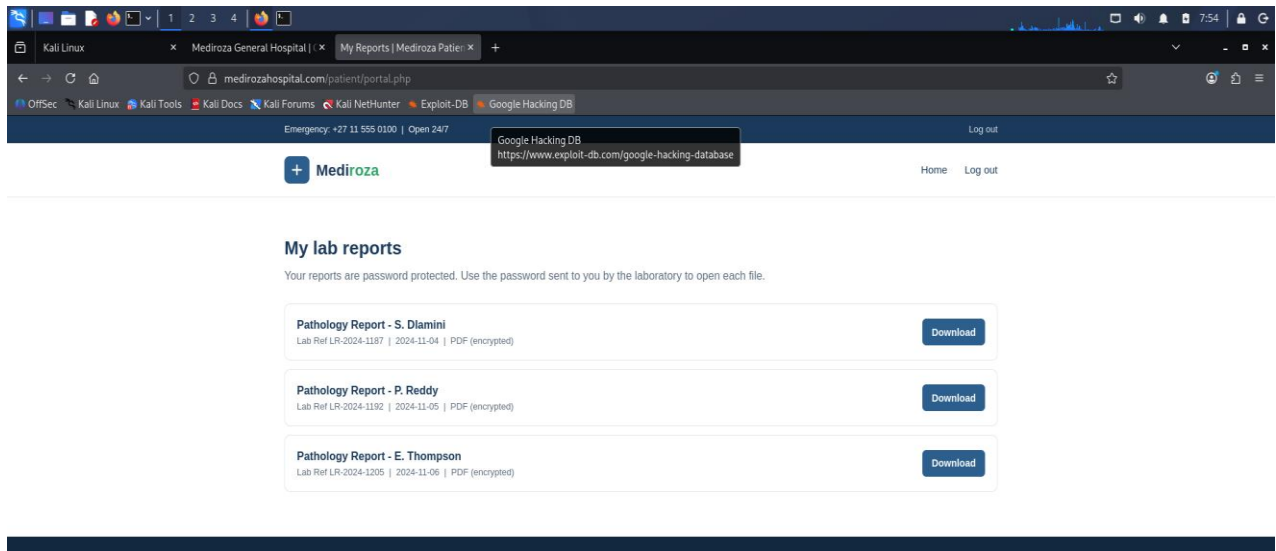
Once inside the portal via the injection bypass, I found three patient lab report PDFs available for download. These are confidential medical files that should be visible only to the named patient and their doctor.

Steps Taken

Signing in with the injection payload dropped me onto the portal page, which listed three downloadable reports.

```
patient_report_1.pdf
patient_report_2.pdf
patient_report_3.pdf
```

I downloaded all three.



3.3 Finding 4 — Weak, Easily Cracked PDF Passwords

Risk Rating: High

Description

Each PDF was password-protected, but the passwords chosen were weak enough to appear in common wordlists, making automated cracking trivial. Simple passwords like these offer little real protection for sensitive medical files.

Steps Taken

I used the Networkwalks Hash Calculator to pull a crackable hash from each file, then ran each hash through the Networkwalks Password Cracker.

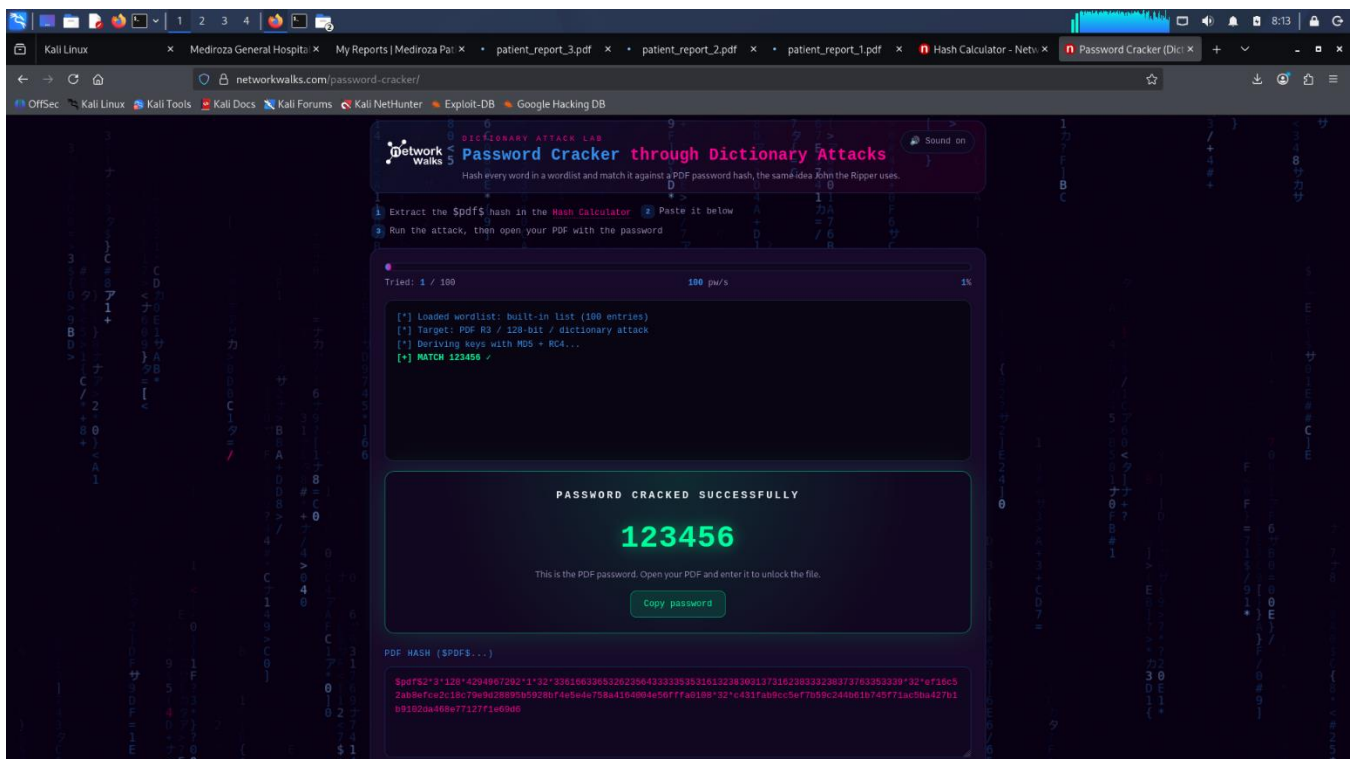
Reports 1 and 2 fell almost immediately using the tool's built-in 100-word default list.

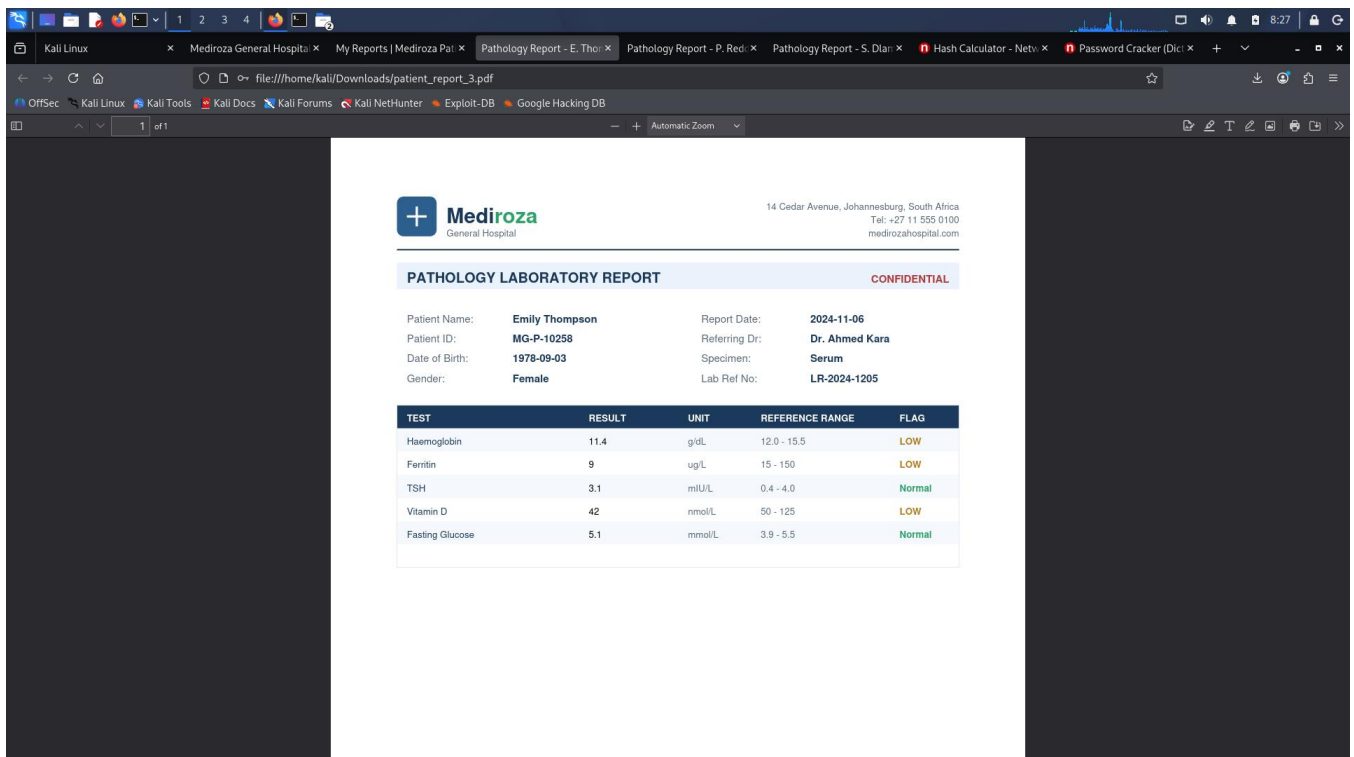
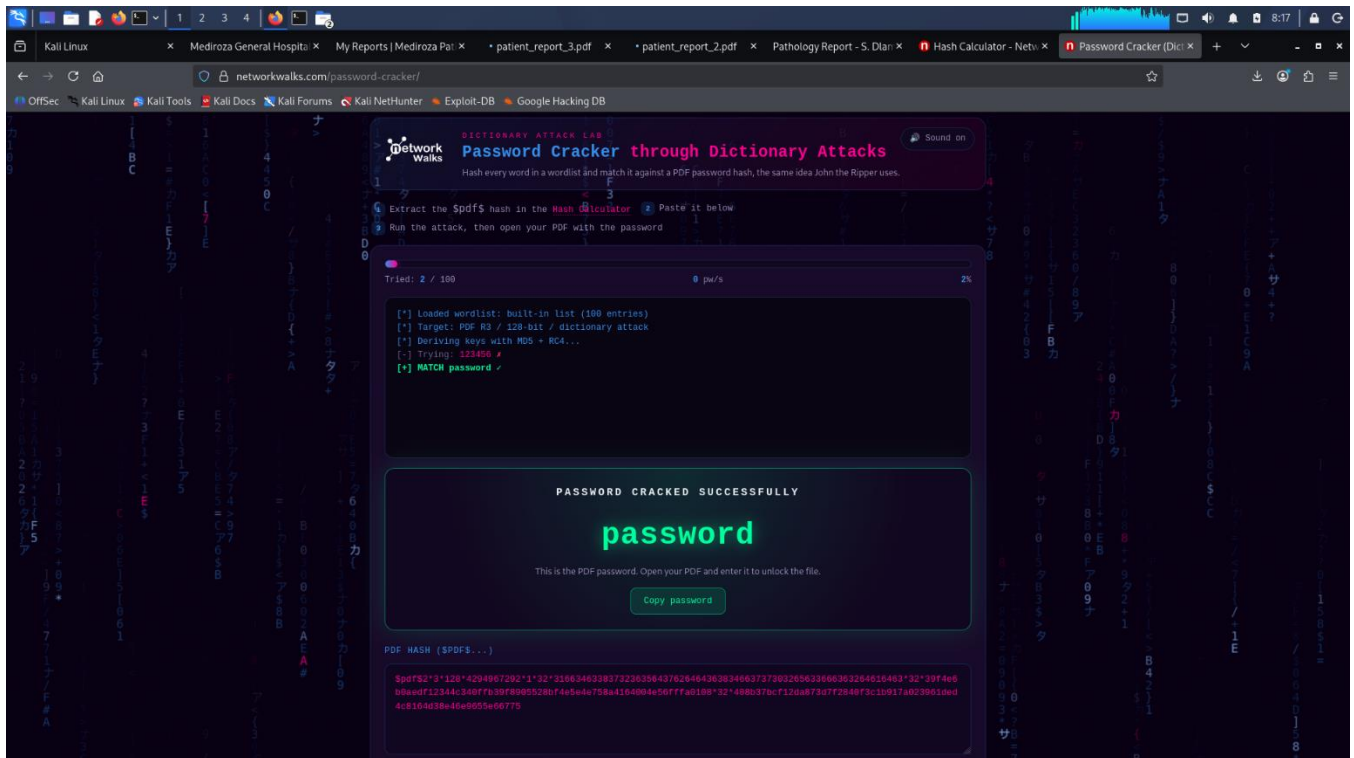
```
RESULTS
patient_report_1.pdf -> 123456
patient_report_2.pdf -> password
```

Report 3 didn't crack against that list, so I switched to a larger wordlist (the JTR default list) and reran the attack.

```
patient_report_3.pdf -> !@#$%^&
```

With the passwords in hand, I opened each PDF and read the confidential patient medical data inside.





3.4 Finding 5 — Sensitive Metadata Left in a Patient PDF

Risk Rating: Medium

Description

PDF files can carry hidden metadata — author name, creation date, custom comments — that isn't shown when the document is simply read but can be pulled out with tools such as exiftool. In this case, report 3 held an internal note from IT staff that pointed straight at a confidential backup file on the server.

Steps Taken

I first decrypted report 3 with qpdf so that exiftool could read every metadata field — a still-locked PDF only exposes its encryption type.

```
qpdf --password='!@#$$%^&' --decrypt patient_report_3.pdf report3_open.pdf
```

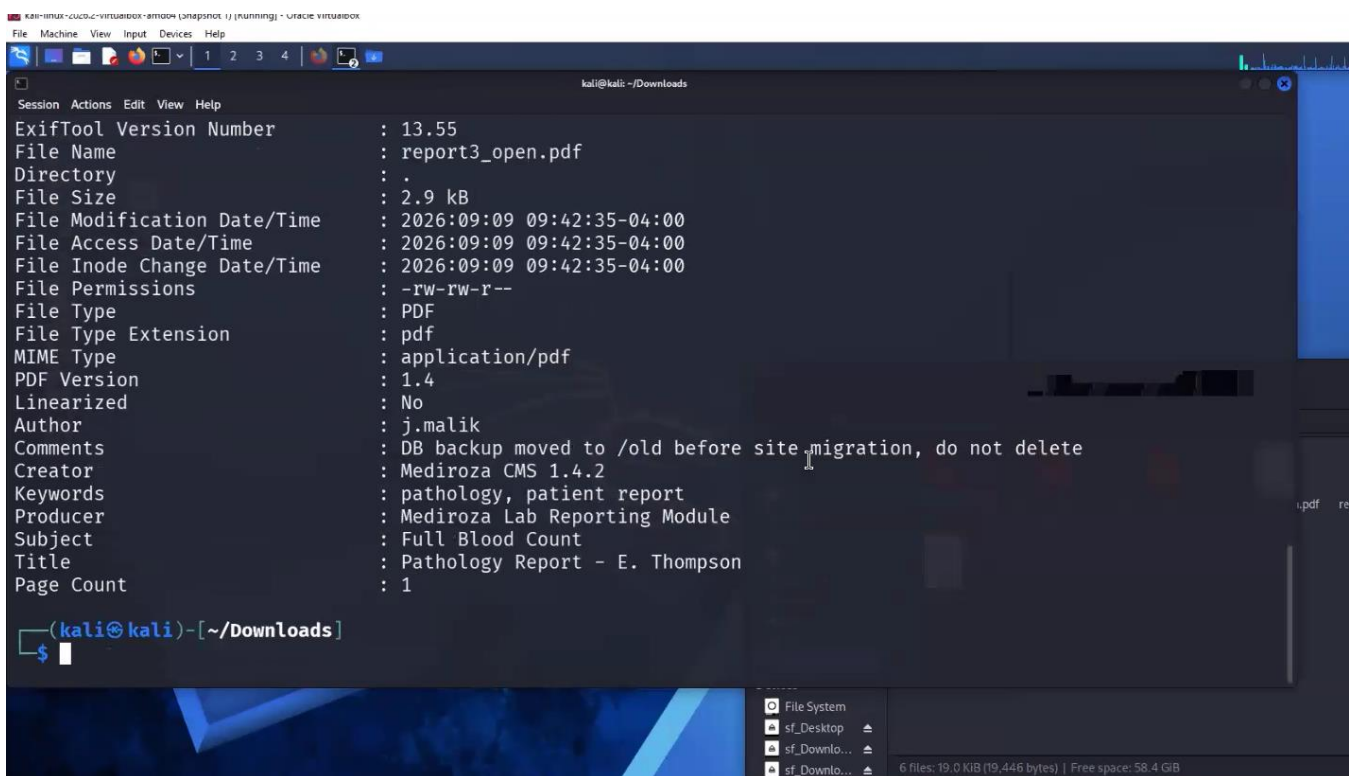
I then ran exiftool against the unlocked file.

```
exiftool report3_open.pdf
```

Key fields from the output:

```
Author : j.malik
Comments : DB backup moved to /old before site migration, do not delete
```

This note, left by IT administrator Jameel Malik (j.malik), gave away the exact location of a database backup on the server.



3.5 Finding 6 — Forgotten Backup Folder With Directory Listing Enabled

Risk Rating: Critical

Description

Directory listing is a server misconfiguration that shows a folder's full contents like a file browser whenever there's no index page present. The /old folder on this server had directory listing switched on, exposing a database backup to anyone who browsed to it. I had already flagged this folder during initial reconnaissance, since it was listed as a disallowed path in robots.txt.

Steps Taken

robots.txt had already pointed me toward /old during recon, and the metadata clue from Finding 5 confirmed this was where the backup lived. I browsed to the folder directly.

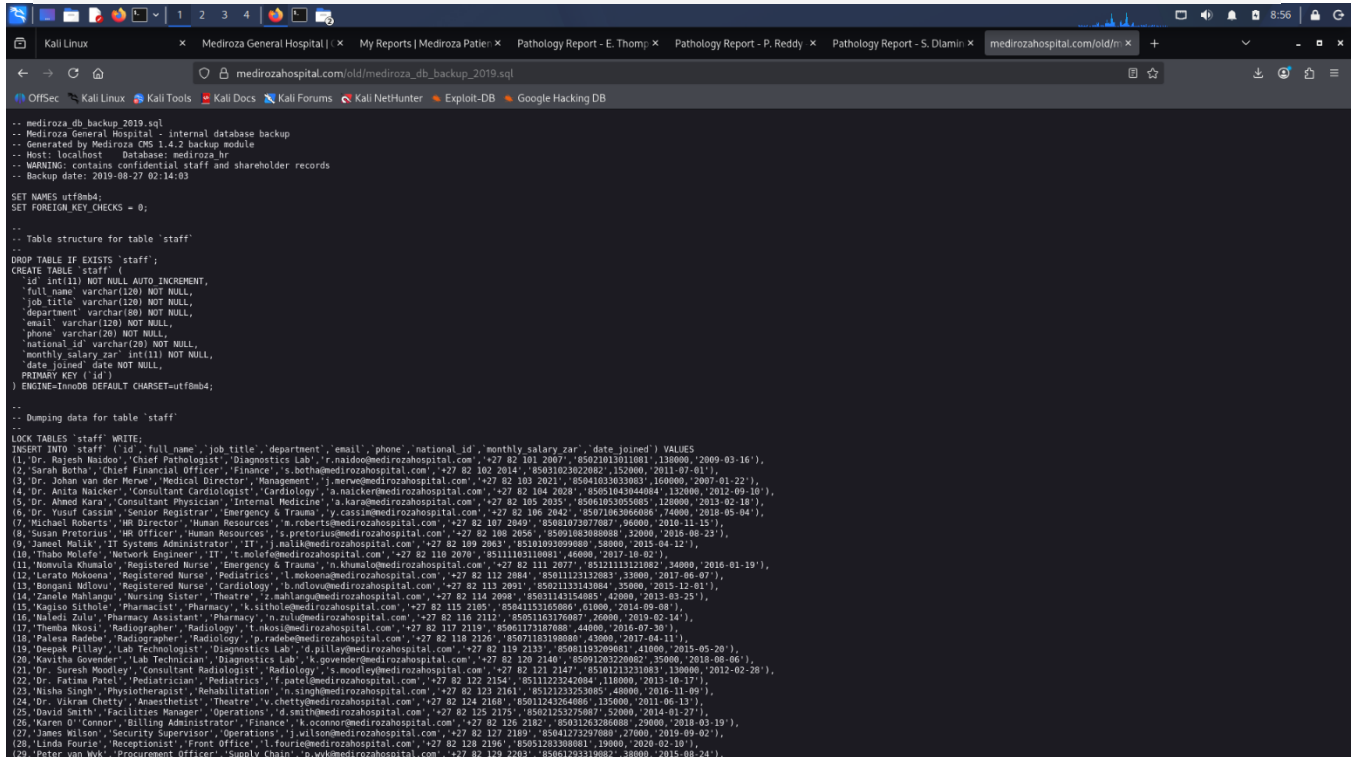
```
https://medirozahospital.com/old/
```

Directory listing was on, and the backup file was immediately visible.

```
mediroza_db_backup_2019.sql
```

I retrieved it with wget.

```
wget https://medirozahospital.com/old/mediroza_db_backup_2019.sql
```



```
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - Internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table `staff`
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(60) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,Dr. Rajesh Naidoo,Chief Pathologist,Diagnostics Lab,r.naidoo@medirozahospital.com,+27 82 181 2007,+55021013011001,135000,2009-03-16'),
(2,Sarah Botha,Chief Financial Officer,Finance,s.botha@medirozahospital.com,+27 82 182 2014,+55031023022002,152000,2011-07-01'),
(3,Dr. Johan van der Merwe,Medical Director,Management,j.merwe@medirozahospital.com,+27 82 103 2021,+55041033033003,160000,2007-01-22'),
(4,Dr. Anita Naicker,Consultant Cardiologist,Cardiology,a.naicker@medirozahospital.com,+27 82 184 2028,+55051043044004,132000,2012-09-18'),
(5,Dr. Ahmed Kara,Consultant Physician,Internal Medicine,a.kara@medirozahospital.com,+27 82 185 2035,+55061053055005,120000,2013-02-18'),
(6,Dr. Yusuf Cassim,Senior Registrar,Emergency & Trauma,y.cassim@medirozahospital.com,+27 82 186 2042,+55071063066006,74000,2018-05-04'),
(7,Michael Roberts,HR Director,Human Resources,m.roberts@medirozahospital.com,+27 82 187 2049,+55081073077007,96000,2016-11-15'),
(8,Susan Pretorius,HR Officer,Human Resources,s.pretorius@medirozahospital.com,+27 82 188 2056,+55091083088008,52000,2015-08-23'),
(9,Jameel Malik,IT Systems Administrator,IT,j.malik@medirozahospital.com,+27 82 189 2063,+55101093099009,58000,2015-04-12'),
(10,Thabo Molefe,Network Engineer,IT,t.molefe@medirozahospital.com,+27 82 118 2070,+5511103110001,46000,2017-10-02'),
(11,Munoliwa Khumalo,Registered Nurse,Emergency & Trauma,m.khumalo@medirozahospital.com,+27 82 111 2077,+55121111121002,34000,2016-01-19'),
(12,Lerato Mokoena,Registered Nurse,Pediatrics,l.mokoena@medirozahospital.com,+27 82 112 2084,+55011211212003,33000,2017-06-07'),
(13,Bungani Ndlovu,Registered Nurse,Cardiology,b.ndlovu@medirozahospital.com,+27 82 113 2091,+55021131133004,35000,2015-12-01'),
(14,Zamele Mlambe,Registered Nurse,Theatre,z.mlambe@medirozahospital.com,+27 82 114 2098,+55031141144005,42000,2013-05-25'),
(15,Kagiso Sithole,Pharmacist,Pharmacy,k.sithole@medirozahospital.com,+27 82 115 2105,+55041151155006,61000,2014-09-08'),
(16,Haleli Zulu,Pharmacy Assistant,Pharmacy,h.zulu@medirozahospital.com,+27 82 116 2112,+55051161166007,26000,2019-02-14'),
(17,Themba Mosisi,Radiographer,Radiology,t.mosisi@medirozahospital.com,+27 82 117 2119,+55061171177008,44000,2016-07-30'),
(18,Palena Radebe,Radiographer,Radiology,p.radebe@medirozahospital.com,+27 82 118 2126,+55071181188009,43000,2017-04-11'),
(19,Deepak Pillay,Lab Technologist,Diagnostics Lab,d.pillay@medirozahospital.com,+27 82 119 2133,+55081191199010,41000,2015-05-20'),
(20,Kavitha Govender,Lab Technician,Diagnostics Lab,k.govender@medirozahospital.com,+27 82 120 2140,+55091201202002,35000,2018-08-06'),
(21,Dr. Suresh Moodley,Consultant Radiologist,Radiology,s.moodley@medirozahospital.com,+27 82 121 2147,+55101211213003,130000,2012-02-28'),
(22,Dr. Fatima Patel,Paediatrician,Pediatrics,f.patel@medirozahospital.com,+27 82 122 2154,+55111221224004,118000,2013-10-17'),
(23,Nisha Singh,Physiotherapist,Rehabilitation,n.singh@medirozahospital.com,+27 82 123 2161,+55121231235005,48000,2016-11-09'),
(24,Dr. Vikram Chetty,Anaesthetist,Theatre,v.chetty@medirozahospital.com,+27 82 124 2168,+55011241246006,135000,2011-06-13'),
(25,David Smith,Facilities Manager,Operations,d.smith@medirozahospital.com,+27 82 125 2175,+55021251252007,22000,2014-01-27'),
(26,Karen O'Connor,Billing Administrator,Finance,k.oconnor@medirozahospital.com,+27 82 126 2182,+55031261263008,29000,2018-03-19'),
(27,James Wilson,Security Supervisor,Operations,j.wilson@medirozahospital.com,+27 82 127 2189,+55041271277009,27000,2019-09-02'),
(28,Linda Fourie,Receptionist,Front Office,l.fourie@medirozahospital.com,+27 82 128 2196,+55051281288001,19000,2020-02-19'),
(29,Peter van Wyk,Procurement Officer,Supply Chain,p.vanwyk@medirozahospital.com,+27 82 129 2203,+55061291299002,38000,2015-08-24').
```

3.6 Finding 7 — Confidential Staff Pay and Shareholder Data Stored in Plain Text

Risk Rating: Critical

Description

The database backup held highly sensitive data in plain text: full name, job title, email address, phone number, national ID number, and monthly salary (in ZAR) for all 30 hospital employees, plus the names and ownership percentages of the hospital's 10 shareholders. None of this was protected in any way, and all of it was reachable by anyone who visited the /old folder.

Steps Taken

I opened the SQL file in a text editor. Since the data was in raw SQL form, I copied the staff INSERT statements and used ChatGPT to turn them into a readable table.

```
Present this SQL data as a readable table showing name, job title, department and monthly salary.
```

I repeated the same process for the shareholder records.

```
Present this SQL data as a readable table showing shareholder name, share percentage and share class.
```

This gave me a clear view of every employee's private salary and the hospital's full ownership structure.

I also cross-checked the PDF metadata's Author field, j.malik, against the staff table and confirmed it corresponds to Jameel Malik, the IT Systems Administrator — tying all three parts of the chain together.

SQL data formatted as readable tables

Staff

Salaries are monthly, in South African rand (ZAR).

Name	Job Title	Department	Monthly Salary
Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	R138,000
Sarah Botha	Chief Financial Officer	Finance	R152,000
Dr. Johan van der Merwe	Medical Director	Management	R160,000
Dr. Anita Naicker	Consultant Cardiologist	Cardiology	R132,000
Dr. Ahmed Kara	Consultant Physician	Internal Medicine	R128,000
Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	R74,000
Michael Roberts	HR Director	Human Resources	R96,000
Susan Pretorius	HR Officer	Human Resources	R32,000
Jameel Malik	IT Systems Administrator	IT	R58,000
Thabo Molefe	Network Engineer	IT	R46,000
Nomvula Khumalo	Registered Nurse	Emergency &	R34,000

+ Write a message...

SQL data formatted as readable tables

Formatting hospital database records into readable tables.

Shareholders

Shareholder	Share %	Share Class
Dr. Rajesh Naidoo	18.00%	Ordinary
Cedar Health Holdings (Pty) Ltd	15.00%	Ordinary
Dr. Johan van der Merwe	12.00%	Ordinary
Reddy Family Trust	11.00%	Ordinary
Thabo Molefe	10.00%	Ordinary
Sarah Botha	9.00%	Ordinary
Dr. Ahmed Kara	8.00%	Preferential
Naledi Zulu	7.00%	Ordinary
Michael Roberts	6.00%	Ordinary
Dr. Vikram Chetty	4.00%	Preferential

Staff

Salaries are monthly, in South African rand (ZAR).

Name	Job Title	Department	Monthly
------	-----------	------------	---------

+ Write a message...

Full Attack Chain Summary

Below is the complete path from having no access at all to full exposure of sensitive data, showing how each finding fed into the next.

- **Step 1:** robots.txt revealed three hidden folders: /patient, /staff, and /old.
- **Step 2:** Differing error messages on the patient login page confirmed admin as a valid account (Finding 1).
- **Step 3:** A single quote in the username field triggered a database error, confirming SQL injection (Finding 2).
- **Step 4:** The payload admin' -- bypassed the login entirely, granting access to the patient portal (Finding 2).
- **Step 5:** Three confidential patient lab report PDFs were downloaded from the portal (Finding 3).

- **Step 6:** The Networkwalks Password Cracker cracked all three PDF passwords — reports 1 and 2 with the built-in list, report 3 with the larger JTR list (Finding 4).
- **Step 7:** exiftool on the unlocked report 3 revealed a hidden comment from j.malik pointing to /old (Finding 5).
- **Step 8:** The /old folder had directory listing enabled, exposing the database backup (Finding 6).
- **Step 9:** The backup exposed the salaries of 30 employees and the shareholdings of 10 shareholders in plain text (Finding 7).

4. Recommendations and Remediation

4.1 Fix Username Enumeration

Update the login page so that every failed attempt returns the same generic message, regardless of whether the username or the password was wrong — for example, "Invalid credentials. Please try again."

4.2 Fix SQL Injection

Replace the current login query with a parameterised query or prepared statement. This keeps the SQL structure separate from user input, so no crafted input can alter the query itself. This is the single most important fix in this report.

```
// Safe example using a PHP PDO prepared statement
$stmt = $pdo->prepare("SELECT * FROM users WHERE username = ? AND password = ?");
$stmt->execute([$username, $password]);
```

4.3 Fix PDF Access and Password Strength

Move the PDF files outside the web root so the web server can't serve them directly. Require a server-side authentication check before any file is served. Where passwords are still used, enforce a minimum length of 12 characters mixing uppercase, lowercase, numbers, and symbols.

4.4 Strip PDF Metadata

Strip metadata from files before they're distributed. Internal notes or comments from staff should never travel inside files that leave the organisation. The following command removes all metadata:

```
exiftool -all= patient_report_3.pdf
```

4.5 Fix Directory Listing and Remove the Backup

Disable directory listing across all folders by adding **Options -Indexes** to the Apache configuration or .htaccess file. Delete the database backup from /old immediately — backups should never live inside the web root, and should instead be kept in a private, access-controlled location outside anything publicly reachable.

5. Conclusion

This assessment traced a complete attack path from the public login page all the way to highly sensitive internal data, without requiring advanced tooling or specialist knowledge. Every vulnerability identified is well documented and has an established fix. I recommend the client resolve all Critical and High findings before this system is used to handle or store real patient data.

Submitted by: Like Muyambango

Cybersecurity Mentor: Waqas Karim, CCIE

Organisation: Networkwalks

Batch B082 | Week 4 Capstone Project

This report was produced as part of a supervised training exercise run by Networkwalks. The target system was authorised for security testing in advance. These techniques must never be used against any system without explicit, written permission from its owner.

This report is submitted as part of the Networkwalks B082 Cybersecurity Internship, Week 4 Capstone Project. All testing took place in a controlled environment with written authorisation from the client. These techniques must never be applied to any system without explicit written permission from the owner.